

BACHELOR PROEF

Extra opdrachten

Nalani Van Beemen
Elektronica-ICT – Cloud & Cybersecurity

2024 - 2025

Stagebedrijf Infosentry
Begeleiders: Liesbeth Kenens & Stijn Cornelis

INFOSENTRY
get assured

Inhoudsopgave

1. OWASP SAMM	4
2. ISO 27001	5
2.1. Wat is ISO27001?	5
2.2. ISO 27001:2017 naar ISO 27001:2022	6
2.3. Interne audit met Vanta	6
2.4. Externe audit Infosentry	7
3. INCIDENT RESPONSE PLAYBOOK	8
4. BUSINESS CONTINUITY PLAN (BCP)	9
5. VANTA PRACTICAL ONBOARDING CUSTOMERS	10
6. INTERNAL KNOWLEDGE BASE	10
7. CISO ASSISTANT	11

Inleiding

Dit document dient als aanvulling op het stageverslag en is bedoeld om een aantal aanvullende opdrachten en activiteiten toe te lichten die ik tijdens mijn stage heb uitgevoerd. Deze opdrachten waren niet vooraf opgenomen in het oorspronkelijke stageplan, maar kwamen spontaan of op vraag van de organisatie tot stand.

1. OWASP SAMM

In de eerste periode van mijn stage kreeg ik al snel de opdracht om onderzoek te doen naar OWASP SAMM. De aanleiding hiervoor was dat de organisatie reeds werkte volgens de ISO 27001-standaard voor informatiebeveiliging, maar dat deze norm vrij algemeen blijft en weinig concrete handvatten biedt specifiek voor softwareontwikkeling. Er was bijgevolg nood aan een praktisch kader dat security beter integreert in het ontwikkelproces en tegelijkertijd de aansluiting bewaart met bestaande compliance-eisen. Over deze opdracht heb ik ook een interne presentatie gegeven om mijn keuze en aanbevelingen verder toe te lichten.

OWASP SAMM is een open standaard ontwikkeld door de Open Worldwide Application Security Project (OWASP) en biedt een gestructureerd raamwerk om de beveiliging binnen softwareontwikkelingsprocessen te verbeteren. Het model is specifiek ontworpen om organisaties van verschillende grootte en sectoren te ondersteunen in het opbouwen van een passende en effectieve aanpak rond softwarebeveiliging.

OWASP SAMM is opgebouwd rond vijf bedrijfsfuncties: Governance, Design, Implementation, Verification en Operations. Binnen elk van deze functies zijn er verschillende securitypraktijken gedefinieerd, elk met drie maturiteitsniveaus. Door middel van concrete richtlijnen en activiteiten per niveau kunnen organisaties niet alleen hun huidige volwassenheid inschatten, maar ook stapsgewijs verbeteringen plannen. Hierdoor maakt SAMM security-inspanningen meetbaar en beheersbaar.

SAMM biedt een mogelijkheid om een self-assessment vragenlijst in te vullen of te laten invullen, zo kan men een beter zicht krijgen op de maturiteit. Dit kan gedaan worden aan de hand van de SAMM spreadsheet, dit is in Excel en dient handmatig ingevuld te worden. Ook dient deze dan handmatig geanalyseerd te worden.

De tweede optie is de online SAMMY tool. Hierbij worden dezelfde vragen gesteld maar kan dit online in het platform ingevuld worden. Men kan de vragenlijst toewijzen aan bepaalde personen en laten controleren door bijvoorbeeld een CISO. Hier is samenwerken ook mogelijk.

Mijn conclusie is dat deze vragenlijst een aanvulling kan zijn. Maar echter vond ik het platform niet vrij duidelijk. Ik denk dat het zich nog in de ontwikkelingsfase bevindt en nu nog niet optimaal is. Daarom zou ik het nu niet direct aanraden.

De slides van de presentatie die ik hierover gegeven heb kan u terugvinden in Bijlagen 1: OWASP presentatie.

2. ISO 27001

Tijdens mijn stage ben ik intensief in contact gekomen met de ISO 27001-standaard voor informatiebeveiliging. Deze internationale norm legt eisen vast voor het opzetten, implementeren, onderhouden en continu verbeteren van een Information Security Management System (ISMS). ISO 27001 vormt een belangrijk referentiekader voor organisaties die hun informatiebeveiliging structureel willen aanpakken en aantoonbaar willen maken. ISO 27001 is geen verplichte maar vrijblijvende norm.

Gedurende mijn stageperiode heb ik actief bijgedragen aan verschillende onderdelen van het ISO 27001-traject binnen verschillende organisaties. Zo heb ik zelfstandig beleidsdocumenten opgesteld, in lijn met de eisen van de norm en afgestemd op de specifieke context van het bedrijf. Hierbij ging het onder meer om richtlijnen rond toegangsbeheer, incidentmanagement en gegevensbescherming.

Om dit te doen, heb ik gebruik gemaakt van handboeken, internet en voorbeeld documenten. Dit was niet makkelijk in het begin.

Daarnaast ben ik regelmatig meegegaan naar klanten. Tijdens deze bezoeken werden bestaande processen geëvalueerd aan de hand van de normvereisten, werden verbeterpunten geïdentificeerd en werd advies gegeven over concrete maatregelen om de compliancegraad te verhogen. Deze ervaring gaf mij niet alleen diepgaand inzicht in de praktische toepassing van ISO 27001, maar ook in de manier waarop organisaties omgaan met informatiebeveiliging.

Door deze nauwe betrokkenheid bij zowel het opstellen van beleid als het uitvoeren van assessments, heb ik een grondige en praktijkgerichte kennis ontwikkeld van ISO 27001 en het bijbehorende audit- en complianceproces.

2.1. Wat is ISO27001?

ISO 27001 is een internationale standaard die richtlijnen en vereisten vastlegt voor het opzetten, implementeren, onderhouden en continu verbeteren van een Information Security Management System (ISMS). De norm werd ontwikkeld door de International Organization for Standardization (ISO) in samenwerking met de International Electrotechnical Commission (IEC) en is officieel bekend onder de naam ISO/IEC 27001:2022 (voor de meest recente versie).

Het doel van ISO 27001 is om organisaties te helpen hun informatiebeveiliging op een systematische en risicogebaseerde manier te beheren. Daarbij wordt niet alleen gekeken naar technische maatregelen, maar ook naar beleidsprocessen, organisatorische structuren en menselijke factoren die de beveiliging van informatie kunnen beïnvloeden.

Een ISMS volgens ISO 27001 biedt een raamwerk waarin processen, risicoanalyses, controles en verbetermaatregelen continu op elkaar afgestemd worden. De norm benadrukt het principe van de Plan-Do-Check-Act (PDCA)-cyclus, waarbij organisaties hun beveiligingsmaatregelen voortdurend evalueren en optimaliseren.

De belangrijkste elementen van ISO 27001 zijn:

- Contextbepaling: Welke interne en externe factoren van invloed zijn op informatiebeveiliging?
- Risicobeheer: Identificeren, evalueren en behandelen van risico's die de vertrouwelijkheid, integriteit en beschikbaarheid van informatie bedreigen.
- Leiderschap en betrokkenheid: De directie moet actief betrokken zijn bij de implementatie en ondersteuning van het ISMS.

- Beheersmaatregelen: ISO 27001 verwijst naar een uitgebreide set van beveiligingsmaatregelen (Annex A), waaronder toegangsbeheer, cryptografie, fysieke beveiliging, incidentmanagement en leveranciersrelaties.
- Monitoring, evaluatie en verbetering: Door middel van interne audits, management reviews en voortdurende verbetering wordt het ISMS up-to-date gehouden en aangepast aan veranderende omstandigheden.

ISO27001 is zodanig opgesteld dat ze toepasbaar is op elke organisatie, ongeacht de omvang of sector. Voordelen van een sterk ISMS zijn:

- Bescherming van gevoelige informatie tegen ongeautoriseerde toegang of verlies.
- Verbetering van het vertrouwen bij klanten, partners en andere stakeholders.
- Vermindering van risico's op beveiligingsincidenten en de daaruit voortvloeiende schade.
- Naleving van wettelijke en contractuele eisen inzake informatiebeveiliging.
- Concurrentievoordeel bij aanbestedingen en klanten die specifieke eisen stellen aan informatiebeveiliging.

Organisaties kunnen zich officieel laten certificeren door een erkende certificeringsinstelling. Hiervoor dienen zij een interne en externe audit te ondergaan. Meer informatie over dit proces is terug te vinden in mijn realisatiedocument. Deze certificering toont aan dat het bedrijf matuur is en internationale best practices toepast op vlak van informatiebeveiliging.

Conclusie, ISO 27001 biedt een gestructureerd kader waarmee organisaties risico's kunnen beheersen, compliance kunnen aantonen en vertrouwen kan versterken.

2.2. ISO 27001:2017 naar ISO 27001:2022

Ook ben ik in contact gekomen met een klant die gecertificeerd was in de ISO27001:2017 norm. De :2017 staat voor het jaartal 2017, ondertussen is er een recentere versie, :2022, van het jaar 2022 dus. Dit project nam mij mee in de evolutie van de norm, zo kon ik de verschillen tussen beide versies zien.

In ISO 27001:2022 werden nieuwe beveiligingsmaatregelen toegevoegd en andere controles samengevoegd. Hierdoor zou de norm beter af stemmen op de actuele dreigingen en technologische ontwikkelingen.

De betrekking bij dit project gaf mij meer inzicht in de norm, en ook de oorsprong. Ik begrijp de logica en prioriteiten beter. Dit project heeft zeker mijn kennis verruimt.

2.3. Interne audit met Vanta

Naast mijn onderzoek naar onder anderen Vanta, kreeg ik ook de kans om hier effectief mee te werken. Tijdens mijn stage heb ik een interne ISO 27001 audit mee mogen uitvoeren, in de tool Vanta. Deze klant gebruikt Vanta nu al enige tijd en was al zeer matuur erin. Dit was een heel waardevolle ervaring voor mij en ook enkel positief voor mijn onderzoek. Ik nam zo actief deel aan de interne audit.

Vanta is een automated compliance platform dat organisaties ondersteunt bij het continu monitoren en beheren van hun beveiligingsmaatregelen en compliance-eisen. De tool automatiseert een groot deel van het auditproces, bijvoorbeeld door continu technische controles uit te voeren, documentatie te beheren en takenlijsten op te stellen op basis van de vereisten van ISO 27001 en andere standaarden.

2.4. Externe audit Infosentry

Naast mijn betrokkenheid bij interne audits en verbeterprojecten, kreeg ik ook de mogelijkheid om een externe ISO 27001-audit bij te wonen die plaatsvond bij Infosentry zelf. Deze externe audit werd uitgevoerd door een onafhankelijke certificeringsinstelling, met als doel om te beoordelen of het Information Security Management System (ISMS) van de organisatie nog steeds voldeed aan de eisen van de ISO 27001-norm.

Tijdens deze audit had ik de kans om het volledige proces van dichtbij te volgen. Zo kon ik zien hoe dit in zijn werk ging. Welke vragen stelde de auditor? En hoe legde Infosentry zijn antwoorden/bewijzen klaar? Er werden veel technische controles afgegaan, maar organisatorische aspecten waren ook aanwezig.

Het mogen bijwonen van deze externe audit was een bijzonder leerrijke ervaring. Het bood mij niet alleen inzicht in hoe een audit in de praktijk verloopt, maar ook in welke vragen, bewijzen en onderbouwingen belangrijk zijn tijdens een certificeringstraject. Daarnaast kon ik beter begrijpen hoe een externe auditor onafhankelijkheid bewaakt en welke kritische blik nodig is om compliance objectief te beoordelen.

Het bijwonen van deze externe audit was bijzonder leerrijk voor mij. Zo kon ik zien hoe het echt in de praktijk verloopt en een beter zicht krijgen op de voorbereiding van zo'n audit.

3. Incident response playbook

Tijdens mijn stage heb ik verschillende incident response playbooks opgesteld voor een klant. Een incident response playbook is een gestructureerd stappenplan dat gevolgd moet worden wanneer zich een specifiek incident voordoet. Het concept is vergelijkbaar met een business continuity plan, maar richt zich specifiek op de stappen die ondernomen moeten worden.

Volgende vier playbooks schreef ik uit:

- Data breach
- DDoS-aanval
- Phishing
- Ransomware

Voor elk van deze onderwerpen is het cruciaal om eerst duidelijk te omschrijven wat het incident precies inhoudt. Dit zorgt ervoor dat ook niet-technische medewerkers begrijpen waarmee ze te maken hebben. De playbooks zijn immers bedoeld voor een brede doelgroep binnen de organisatie, niet enkel voor IT-specialisten.

Een goed playbook brengt niet alleen het incident in kaart, maar verduidelijkt ook de mogelijke risico's en gevolgen ervan, en biedt richtlijnen om toekomstige incidenten te voorkomen.

Bij het behandelen van een incident is het belangrijk om snel en gestructureerd informatie te verzamelen.

De onderstaande elementen moeten bij elk incident in kaart worden gebracht. Het betreft essentiële vragen die telkens beantwoord dienen te worden. Afhankelijk van de specifieke omstandigheden kunnen hier bijkomende, situatie gebonden vragen aan worden toegevoegd:

- Wie heeft het incident gemeld? Op welke datum en tijdstip?
- Welke signalen wijzen op een incident? (bv. afwijkend systeemgedrag, verdachte logs, waarschuwingen, ...)
- Hoe is het incident binnengekomen? Welke systemen zijn hierbij betrokken?
- Welke methode is toegepast?
- Wat zijn de gevolgen van het incident? (bv. uitval van systemen, datalekken). Welke gegevens zijn eventueel gelekt? (gebruikersnamen, wachtwoorden, adressen, financiële gegevens, ...)
- Welke betrokkenen zijn er? (klanten, medewerkers, leveranciers, ...)
- Verzamel bewijsstukken (zoals systeemlogs, netwerkverkeer, forensische analyses, screenshots, ...)
- Analyseer de impact van het incident op de organisatie en haar werking.
- Neem onmiddellijke (short-term) maatregelen om verdere verspreiding te voorkomen.
- Bepaal en implementeer structurele (long-term) oplossingen.
- Herstel de normale werking van systemen en processen.
- Handel het incident formeel af.
- Documenteer de "lessons learned" om toekomstige incidenten beter te kunnen voorkomen of aanpakken.

Deze playbooks dienen als basis gebruikt te worden wanneer er zich een incident voordoet. Het is belangrijk dat de stappen in chronologische volgorde correct worden uitgevoerd. Het verzamelen en duidelijk uitschrijven van relevante informatie is essentieel. Deze documentatie vormt de basis voor 'lessons learned'. Hierbij wordt achteraf bekeken hoe men de kans op een soortgelijk incident kan verminderen naar de toekomst toe. Ook kunnen hier betere short-term oplossing uit komen en gaat men sneller en effectiever kunnen reageren wanneer dit een volgende keer voorvalt.

De playbooks zijn niet publiek beschikbaar op mijn online portfolio, aangezien ze specifiek werden opgesteld voor een klant en vertrouwelijke informatie bevatten. Op verzoek kunnen deze documenten worden ingezien, maar ze worden niet openbaar gepubliceerd.

4. Business continuity plan (BCP)

Tijdens mijn stage heb ik ook zelfstandig een Business Continuity Plan (BCP) opgesteld. Een BCP is gelijkaardig aan de playbooks die in het vorige hoofdstuk werden besproken, maar is uitgebreider en richt zich op de continuïteit van de volledige organisatie wanneer er zich een incident voordoet. Terwijl playbooks doorgaans specifiek gericht zijn op de afhandeling van een bepaald incident (zoals een phishingaanval of datalek). Terwijl een BCP focust op het waarborgen en snel herstellen van alle kritieke bedrijfsprocessen, ongeacht het soort incident.

Het opstellen van een BCP begint met het identificeren van de kritieke processen binnen de organisatie. Voor elk van deze processen worden passende herstelstrategieën, back-upprocedures en alternatieve werkwijzen vastgelegd. Bovendien worden er concrete Recovery Time Objectives (RTO's) en Recovery Point Objectives (RPO's) bepaald, zodat duidelijk is binnen welke termijn en met welk dataverlies een proces hersteld moet worden. Ook wordt er per proces een verantwoordelijke aangeduid die instaat voor de uitvoering.

Een essentieel onderdeel van het BCP is de communicatieflow. Deze beschrijft wie bij een incident gecontacteerd moet worden, op welke manier en in welke volgorde. Hierbij wordt rekening gehouden met zowel interne belanghebbenden (zoals IT, management en communicatieafdelingen) als externe partijen, waaronder leveranciers, klanten en toezichthoudende autoriteiten. Er wordt tevens in kaart gebracht welke regulatory bodies (zoals de Gegevensbeschermingsautoriteit of het NIS-contactpunt) regelmatig opgevolgd worden voor updates en richtlijnen, en welke supervising authorities verplicht gecontacteerd moeten worden bij specifieke incidenten. Indien van toepassing wordt ook een Special Interest Group (SIG) gedefinieerd, bestaande uit sleutelfiguren die tijdens crisissituaties samenwerken om weloverwogen beslissingen te nemen.

De recovery procedures binnen het BCP worden op gelijkaardige wijze uitgewerkt als in een incident playbook, maar worden aangevuld met rolverdeling en tijdsschema's. Elke actie is gekoppeld aan een verantwoordelijke en dient binnen een specifiek tijdsvenster uitgevoerd te worden. Hierdoor wordt de reactietijd verkort en de coördinatie binnen de organisatie versterkt.

Het doel van dit plan is niet alleen om snel te kunnen reageren op onverwachte gebeurtenissen, maar ook om de impact van incidenten te minimaliseren en het vertrouwen van klanten en stakeholders te behouden.

5. Vanta practical onboarding customers

In het kader van mijn stage heb ik een praktische onboardinggids ontwikkeld voor klanten die hun Vanta-omgeving opzetten. Mijn gebruikershandleiding, Vanta Practical Onboarding Guide, biedt een gestructureerde en stapsgewijze handleiding voor de initiële configuratie en ingebruikname van Vanta.

De gebruikershandleiding behandelt onder andere het instellen van gebruikersrollen en -rechten, het publiceren en beheren van compliance policies, het toevoegen van personeel, en de installatie van de Vanta Agent voor apparaatbeheer. Daarnaast wordt ook aandacht besteed aan het onderscheid tussen standaardrollen en op maat gemaakte rollen, de integratie van bestaande identity providers, en het belang van correcte device compliance monitoring.

De onboardinggids is ontwikkeld om klanten een duidelijke leidraad te bieden, waardoor zij zelfstandig en efficiënt hun Vanta-omgeving kunnen configureren. Dit vermindert de nood aan intensieve begeleiding door consultants en verkort de implementatietijd. Bovendien zorgt de handleiding ervoor dat kritische stappen niet worden overgeslagen, wat de algemene compliance- en beveiligingsgraad van de organisatie verhoogt.

Ik vond het opstellen van deze gebruikershandleiding zeer fijn. Ik heb op deze manier zelf het platform wat beter kunnen leren kennen, alsook mijn kennis proberen om te zetten naar mensentaal en hier een leuke layout aan gegeven. Ik ben benieuwd of deze handleiding volwaardig gaat zijn als ze effectief wordt uitgetest. Alles kan altijd verbeterd worden.

6. Internal knowledge base

Later ben ik ook gestart met het opzetten van een interne knowledge base binnen Loop. Deze plek is bedoeld als een centrale en toegankelijke plaats waar medewerkers alle noodzakelijke informatie kunnen terugvinden die zij nodig hebben in hun dagelijkse werklevens.

De knowledge base bevat onder andere werkinstructies, praktische handleidingen en antwoorden op veelgestelde vragen. Daarnaast ben ik bezig met het opstellen van templates voor alle relevante policies. Deze templates kunnen door medewerkers eenvoudig worden overgenomen of als voorbeeld gebruikt worden bij het opstellen van nieuwe documenten. Zo kan men tijd besparen, fouten vermeiden en efficiënter te werk gaan. Maar ook is dit bedoeld voor nieuwe collega's als houdvast.

Het uiteindelijke doel van dit project is om een centrale en betrouwbare informatiebron te creëren waar medewerkers snel en gemakkelijk alles kunnen vinden wat zij nodig hebben om hun taken correct en efficiënt uit te voeren.

Door het opbouwen van deze knowledge base heb ik geleerd hoe belangrijk duidelijke documentatie en kennisdeling zijn binnen een organisatie.

7. CISO Assistant

Tijdens mijn stage heb ik een grondig onderzoek uitgevoerd naar CISO Assistant, een open source platform dat ondersteuning biedt op vlak van Governance, Risk & Compliance (GRC). Het platform is ontworpen om organisaties te helpen bij het opzetten en beheren van een Information Security Management System (ISMS), inclusief interne audits en rapportering.

CISO Assistant kan zowel als Software-as-a-Service (SaaS) afgenomen worden (vanaf €39 per contributor per maand), als volledig zelf gehost worden, wat alle operationele kosten doet wegvallen. Ik heb dit zelf natuurlijk uitgetest, en ben tot de conclusie gekomen dat dit zeer eenvoudig is.

De gebruikersinterface is overzichtelijk en intuïtief. Het platform laat toe om een domein aan te maken, bijvoorbeeld per klant of afdeling, waarna de scope en het relevante framework gekozen kan worden. Vervolgens wordt een auditproces gestart waarin alle relevante controles per norm of wetgeving opgelijst worden.

Elke controle bevat een duidelijke toelichting over de doelstelling en toepassing ervan. Een belangrijk voordeel is dat controles aan elkaar gelinkt kunnen worden, inclusief mappings naar andere frameworks. Dit bevordert zowel overzicht als consistentie. Daarnaast stelt de tool zelf ook “suggested reference controls” voor — een nuttige ondersteuning bij het opstellen van het ISMS.

Per controle kunnen volgende gegevens geregistreerd worden:

- Compliance status (To do, In progress, In review, Done)
- Assessment resultaat (Not assessed, Partially compliant, Non-compliant, Compliant, Not applicable)
- Observaties en optioneel uploaden van evidence
- Uitzonderingen en actieplannen

De visuele representatie van de vooruitgang is een van de sterke punten van CISO Assistant. Via duidelijke dashboards krijg je een helder beeld van waar je organisatie staat qua maturiteit en naleving.

Hoewel je geen documenten kunt bewerken in het platform, kun je deze wel als evidence uploaden. Een belangrijk aandachtspunt is dat documenten buiten het platform moeten worden opgesteld (bijv. in Word) en handmatig geüpload worden. Bij updates moet het originele bestand verwijderd en opnieuw opgeladen worden — dit maakt versiebeheer omslachtig in vergelijking met tools die wél documentmanagement ondersteunen (zoals Instant27001).

CISO Assistant bevat functionaliteiten om risicoanalyses en actieplannen op te stellen. Er zijn standaard risicomatrices beschikbaar die aangepast kunnen worden aan de organisatiecontext. Hiermee kunnen risico's gecatalogiseerd en gelinkt worden aan controles of maatregelen.

Wat ontbreekt ten opzichte van meer geavanceerde compliance tools zoals Instant27001, zijn voorgemaakte beleidsdocumenten (policies) en templates. Instant27001 heeft meer als doel een documentenhub, terwijl CISO Assistant meer nadruk legt op interactief beheer en compliance tracking.

CISO Assistant biedt verschillende exportmogelijkheden (PDF, Excel, Word, CSV, ZIP), wat belangrijk is voor organisaties die rapportages willen opstellen of gegevens willen migreren. In de praktijk stootte ik hierbij echter op een beperking: het gegenereerde Word-rapport bevatte geen inhoud van de controles, enkel een sjabloonstructuur. Ik vermoedde eerst dat dit aan de trialversie lag, maar ook bij de zelfgehoste versie bleef dit probleem bestaan. Ik heb hierover contact opgenomen via de officiële Discord-server van het project en wacht nog op bevestiging.

Een bijkomende beperking is het moeilijke importproces van een bestaand ISMS. De tool werkt met een vaste interne structuur en ondersteunt geen eenvoudige migratie van bestaande systemen, wat een nadeel kan zijn bij overstap van een ander platform.

Bijlagen

Bijlagen 1: OWASP presentatie (8 slides)

Agenda		INFQSENTRY	
Topic	Gepresenteerd door	Timing	
Application Security OWASP SAMM – SAMMY	Nalani	20 min.	
NIS2 FAQ	Garry & Lisa	20 min.	
BRAINSTORM: NIS2 vereisten vertaling naar implementatie	Iedereen	15 / 20 min.	
Vermelding: nieuwe map tabletop excercises in de knowledge base	Renke	2 min.	

OWASP SAMM - Software Assurance Maturity Model

INFQSENTRY

OWASP SAMM is een framework dat helpt om **security te integreren in softwareontwikkeling**. Het is bedoeld voor organisaties die zelf software ontwikkelen, en biedt een duidelijke structuur om veilige softwareontwikkeling te meten en verbeteren.

Belang: beschermen tegen cyberbedreigingen en inbreuken

Helpt bedrijven te beoordelen **hoe goed hun softwareontwikkeling aansluit** bij bv. ISO 27001.

Functies

- Het geeft **concrete richtlijnen** om security te integreren in het ontwikkelproces
- Stelt verbeterplannen & **roadmaps** op
- Het maakt security **meetbaar** via self-assessments en verbeterplannen

Inhoud

- 5 hoofdstukken
- 90 vragen

5 business functions

INFQSENTRY

Governance

- Beleid & Strategie

Design

- Ontwerp van software

Implementation

- Ontwikkeling & Implementatie

Verification

- Controle & Testen

Operations

- Beheer & Incident Response

Praktijk

INFQSENTRY

Excel vragenlijst

- 90 vragen (dropdown)
- Zelf analyse van scores

SAMMY tool

- Antwoorden valideren
- Meerdere personen
- Automatische verbeterplannen
- Digitaal

INFQSENTRY

DEMO

Kost

INFQSENTRY

Free	Premium	Pro	Enterprise
For small organizations	For growing organizations	For medium-sized organizations	For enterprise organizations
\$0 per user / month (limits apply)	\$25 per user / month invoiced monthly (limits apply)	\$65 starts from per user / month invoiced annually	
Get Started →	Buy	Calculate Price →	Get a quote →
Free features: ✓ 3 user accounts ✓ 3 scopes ✓ 1 Target scope(s) ✓ Standard reporting (limited use) ✓ Multiple assessment frameworks ✓ Mappings with OpenCRE ✓ Full data privacy	Everything from Free plus: ✓ Maximum 10 user accounts ✓ 10 scopes ✓ 10 target scopes ✓ Unlimited standard reports ✓ All assessment frameworks ✓ Control frameworks ✓ Control management ✓ Premium direct mappings ✓ Mapping reports ✓ JIRA integration	Everything from Premium plus: ✓ No limit on user accounts ✓ ∞ scopes ✓ ∞ target scopes ✓ Branded reports ✓ Standard Single Sign-On ✓ SLA ✓ Priority support	Everything from Pro plus: ✓ Custom models ✓ Custom integrations ✓ Custom features ✓ Custom reports ✓ Custom Single Sign-On ✓ Dedicated / on-prem deployment

Vergelijking

INFQSENTRY

Criteria	Excel-bestand	SAMMY-tool
Gebruiksgemak	Simpel	Iets complexer
Samenwerking	Individueel	Samenwerken mogelijk
Validatie	Zelf scores controleren	Antwoorden kunnen gevalideerd worden door anderen (bijv. CISO)
Verbeterplannen	Zelf bepalen	Automatisch gegenereerd
Prijs	Basis is gratis	Basis is gratis

Conclusie

INFQSENTRY

Excel Spreadsheet

- Flexibel en aanpasbaar
- Offline beschikbaar
- Eenmalige assessments

SAMMY

- Samenwerking mogelijk
- Automatische verbeterplannen
- Validatie door bv. CISO



CONTACT

Nalani Van Beemen | Student
r0882111@student.thomasmore.be
Tel. + 32 477 42 06 90

VOLG ONS

www.thomasmore.be
fb.com/ThomasMoreBE
#WeAreMore

THOMAS
MORE